

Mapeo Detallado de Métricas GQM a Requisitos Normativos

Métrica	Objetivos (G)	Preguntas (Q) principales	NIST SP 800-55 / NIST CSF	ENS / NIS2 / Otros
M1: N° anual de ciberincidentes significativos notificados	G1	Q1.1	SP 800-55: métricas de incidentes; NIST CSF: DE.AE, RS.AN	NIS2: notificación de incidentes; ENS: gestión de incidentes
M2: Tasa de incidencia por 100 organizaciones reguladas	G1	Q1.1, Q1.4	SP 800-55: indicadores normalizados	NIS2: supervisión sectorial; ENS: análisis de riesgos
M3: Distribución de incidentes por tipología de ataque	G1	Q1.2	SP 800-55: métricas de amenazas	ENS: análisis de riesgos; NIS2: medidas técnicas proporcionales al riesgo
M4: MTTD de incidentes significativos	G1, G3	Q1.3	SP 800-55: time-based measures; NIST CSF: DE.CM	ENS: detección; NIS2: detección de incidentes
M5: MTTR de incidentes significativos	G1, G3	Q1.3	SP 800-55: time-based measures; NIST CSF: RS.MI	ENS: respuesta; NIS2: respuesta y mitigación
M6: Tiempo medio de recuperación de servicios críticos	G1, G3	Q3.3	SP 800-55: impact & recovery measures; NIST CSF: RC	ENS: continuidad de servicios; NIS2: continuidad del negocio
M7: Índice de implantación de controles clave	G2	Q2.1	SP 800-55: control implementation metrics; NIST CSF: PR.*	ENS: medidas organizativas/técnicas; NIS2: medidas técnicas y organizativas
M8: IGM medio por sector	G2	Q2.2	SP 800-55: maturity & capability metrics	Modelos de madurez; ENS/NIS2: mejora continua
M9: % de procesos críticos con RTO/RPO cumplidos	G3	Q3.1	SP 800-55: continuity metrics; NIST CSF: RC	ENS: continuidad; NIS2: continuidad de servicios esenciales
M10: Ejercicios de crisis y % de lecciones implementadas	G3	Q3.2	SP 800-55: preparedness metrics; NIST CSF: RS.IM, RC.IM	ENS: pruebas de continuidad; NIS2: pruebas y simulacros

M11: Nivel medio de cumplimiento ENS/NIS2	G2, G4	Q4.1	SP 800-55: compliance metrics	ENS: niveles de cumplimiento; NIS2: supervisión y reporting
M12: N° de sanciones y medidas correctoras por sector	G4	Q4.2, Q4.3	SP 800-55: outcome metrics	NIS2: medidas correctoras y sanciones; RGPD: régimen sancionador
M13: % del presupuesto TI dedicado a ciberseguridad	G5	Q5.1	SP 800-55: efficiency & cost metrics	Buenas prácticas de gobierno TI; benchmarks sectoriales
M14: Relación entre inversión y resultados	G1, G2, G5	Q5.2	SP 800-55: effectiveness vs. cost	Gestión de riesgos e inversiones; análisis coste-beneficio
M15: Estimación de pérdidas evitadas / riesgo mitigado	G1, G3, G5	Q5.3	SP 800-55: impact & risk-reduction metrics	Modelos actuariales; seguros de ciberriesgo